

Human-Supervised AI Operations Governance and Audit Trail Specification

A Standards-Aligned Profile for Accountable Agentic Workflows

HAIO-GATS, Version 0.1.0

Paul Garrett Hugel

ORCID iD: [0000-0001-8082-7208](https://orcid.org/0000-0001-8082-7208)

16 September 2026

DOI: [10.5281/zenodo.22800642](https://doi.org/10.5281/zenodo.22800642)

Document status: Public draft scientific specification. This document proposes testable requirements and an interoperability profile. It is not an ISO publication, a legal opinion, or a certification of conformity.

Abstract

Autonomous and semi-autonomous artificial intelligence systems can perform consequential work across multiple tools, repositories, services, and organizational roles. Existing governance frameworks establish valuable expectations for accountability, human oversight, risk management, logging, and provenance, but they do not collectively define an event-level control and evidence protocol for human-supervised agentic operations. This specification defines a testable profile in which a designated human supervisor retains effective operational control; every human and software actor operates under bounded authority; consequential actions pass explicit approval gates; and material events produce authenticated, append-only, independently verifiable provenance records. The profile maps organizational controls to ISO/IEC 42001:2023, ISO/IEC 38507:2022, ISO/IEC 42005:2025, and the NIST AI Risk Management Framework; human oversight and logging controls to Articles 12 and 14 of Regulation (EU) 2024/1689; provenance semantics to W3C PROV; separation of duties to NIST SP 800-53; and cryptographic transparency to IETF RFC 9943 and RFC 9942. It also states the limits of cryptographic evidence: internal hash consistency does not establish actor identity, authorization, statement accuracy, or independent custody. HAIO-GATS is intended as a research and implementation baseline for accountable AI operations, standards development, conformity assessment, and empirical evaluation.

Keywords: AI governance; human oversight; human-in-the-loop; agentic AI; audit trail; provenance; authorization; accountability; transparency service; separation of duties; tamper evidence; conformity assessment.

Contents

1	Scope	3
2	Research basis and design problem	3
3	Normative language and conformance	4
4	System model	4
4.1	Actors and components	4
4.2	Threat model	5
5	Normative requirements	5
5.1	Human supervisory control	6
5.2	Authority and approval	6
5.3	Identity, delegation, and role separation	7
5.4	Event and provenance model	7
5.5	Cryptographic transparency and custody	8
5.6	Privacy, security, and disclosure	9
5.7	Continuity and recovery	9

6	Operational state model	10
7	Conformance tests	10
8	Standards crosswalk	12
9	Scientific claims and limitations	14
9.1	Testable claims	14
9.2	Limitations	14
10	Ethics, privacy, and responsible use	15
11	Conclusion	15
	Declarations	15
	Recommended citation	15
	Declaration of generative AI and AI-assisted technologies in the writing process	16
	References	16
A	Zenodo deposit metadata	17
B	Change record	18

1 Scope

This specification defines governance, control, evidence, and conformance requirements for an AI operations system in which one or more AI agents perform work under the authority and effective supervision of a natural person. It applies to workflows that can read, create, modify, promote, publish, deploy, transmit, or delete digital artifacts or change an external system state.

The specification covers:

- accountable human supervision and intervention;
- authenticated actor identity and bounded delegation;
- explicit authority and approval gates;
- separation of execution, verification, and promotion roles;
- event-level provenance and evidence records;
- append-only, non-equivocating, cryptographically verifiable registration;
- confidentiality, retention, recovery, and independent custody; and
- reproducible conformance tests.

This specification does not define model training methods, model capability evaluations, general AI safety cases, or a universal legal compliance program. Its controls may support those activities by producing attributable and reviewable evidence.

2 Research basis and design problem

The central design problem is that ordinary application logs are often mutable, incomplete, self-attributed, and controlled by the same system whose conduct they describe. A digest or hash chain can detect some subsequent alteration, but an attacker who controls both the record and its self-derived checkpoint can rewrite and rechain the history [17], [18]. Similarly, a valid signature identifies control of a signing key; it does not alone prove that the signer possessed authority, that the statement was accurate, or that a qualified person independently verified the outcome. Digital time-stamping research demonstrates how evidence can be bound to an independently checkable temporal record, motivating external registration while leaving semantic claims to separate controls [19].

Research on AI-agent visibility identifies agent identifiers, real-time monitoring, and activity logging as governance measures [20]. Human-factors research treats automation design as an allocation across types and levels of human interaction, motivating supervisory control defined by capability and authority rather than nominal presence [21]. Classical computer-protection principles motivate least authority and separation of privilege in the allocation of operational roles [22]. These works motivate HAIO-GATS controls; they do not establish that the controls are effective, and they do not collectively define an event-level control and evidence protocol joining human supervision, bounded authority, provenance, transparency, and conformance testing.

A concurrent individual Internet-Draft defines the Agent Audit Trail, a JSON-based logging format for autonomous AI systems with agent identity, action and outcome fields, trust levels, hash chaining, pre-execution recording, and optional signatures [26]. That work is cited as a work in progress rather than an adopted IETF standard. HAIO-GATS addresses complementary governance and conformance concerns by binding event evidence to a designated Human Supervisor, bounded authority, approval gates, role separation, cumulative assurance levels, and independently checkable registration.

HAIO-GATS treats accountability as a composed property:

Accountability evidence = authenticated identity + current authority + recorded human decision + attributable action + preserved evidence + independent verification + independently checkable registration.

This composition connects organizational governance with a technical evidence layer. The human supervisor is part of the control path before and during consequential execution, rather than an observer who reviews a narrative after the action [21].

3 Normative language and conformance

The key words **MUST**, **MUST NOT**, **SHOULD**, **SHOULD NOT**, and **MAY** are to be interpreted as described in BCP 14 (RFC 2119 [15] and RFC 8174 [16]) when they appear in bold uppercase. A conforming implementation **MUST** declare the requirements and conformance level it satisfies, **MUST** publish requirement-by-requirement evidence for every applicable normative requirement, and **MUST** publish evidence from every test in Section 7 whose minimum level is at or below its declared level. Tests above the declared level **MUST** be reported as `not_applicable` with the level-based reason.

Three cumulative conformance levels are defined:

Level G – Governed

Human supervision, actor identity, bounded authority, approval gates, role separation, and complete event capture.

Level T – Transparent

Level G plus signed statements, a verifiable data structure, receipts, append-only history, non-equivocation evidence, and key-compromise procedures for signing and transparency-service keys.

Level A – Assured Level T plus independent custody or a second transparency service, independent verification, tested recovery, and post-recovery reconciliation.

Each conforming implementation **MUST** satisfy every requirement assigned to its declared level and every lower level. Unless a requirement expressly defines level-dependent duties, the minimum levels are:

Level G HS-01 through HS-06; AU-01 through AU-05; ID-01 through ID-04; EV-01 through EV-06; PS-01 through PS-03; and RC-01 through RC-03.

Level T CT-01 through CT-05; CT-07; and PS-04.

Level A ID-05; CT-06; and RC-04.

Normative duties in the system model, threat model, and operational state model apply from Level G unless their text assigns a higher level.

4 System model

4.1 Actors and components

Table 1: Actors and components.

Role or component	Definition
Human Supervisor	A designated natural person who owns the operation, grants or denies authority, makes required go/no-go decisions, monitors execution, and can interrupt or halt the system.
AI Agent	A software agent that proposes or performs work only within a current authority grant.
Executor	The human or software agent that performs an authorized mutation or external action.
Verifier	An actor that evaluates the resulting artifact and primary evidence against stated acceptance criteria.
Committer or Publisher	The actor that promotes an artifact or state through a separately authorized commit, merge, deployment, transmission, or publication gate.
Policy Decision Point	The component that determines whether an actor, action, resource, and context satisfy the applicable authority and approval policy.
Transparency Service	A service that authenticates signed statements, applies a transparent registration policy, records accepted statements in a verifiable data structure, and issues receipts.
Auditor	An independent relying party that validates receipts, replays evidence, checks consistency, and evaluates compliance with this specification.

4.2 Threat model

The implementation **MUST** address at least the following threats: unauthorized scope expansion; ambiguous or replayed approvals; false actor attribution; compromised agent credentials; role substitution; executor self-verification; omission or alteration of events; reordering, deletion, or rechainning of records; split-view or equivocation by an evidence service; compromise of signing or transparency keys; privacy leakage through logs; partial writes and interrupted publication; and recovery from stale or inconsistent backups. To address a threat at the declared conformance level, the implementation **MUST** either mitigate it through requirements applicable at that level or identify it as a residual risk, state why the higher-level control is absent, and record the Human Supervisor’s explicit acceptance or rejection of that risk.

The trusted computing base and residual risks **MUST** be declared. A claim of “tamper-proof” or “immutable” **MUST NOT** be made unless the implementation demonstrates the applicable threat assumptions and enforcement mechanism. “Tamper-evident” is the preferred claim when alteration can be detected but not prevented.

5 Normative requirements

5.1 Human supervisory control

HS-01 Designation. Before an AI agent receives operational authority, the operation **MUST** identify exactly one accountable Human Supervisor and **MUST** record the supervisor's authenticated identifier.

HS-02 Informed decision. Before a consequential approval, the supervisor **MUST** receive the proposed action, intended purpose, affected resources, requested authority, expected outcome, material risks, evidence available, acceptance criteria, and rollback or containment procedure.

HS-03 Effective control. The supervisor **MUST** be able to approve, reject, constrain, pause, interrupt, override, reverse where technically possible, and safely halt an operation. Intervention controls **MUST** function through a control path that does not depend on voluntary cooperation from the acting AI agent. The implementation **MUST** declare a maximum halt latency for each governed operation or documented risk class, measured from acceptance of the authenticated supervisor halt request to entry into the declared safe state, and **MUST** define the response when that bound is exceeded.

HS-04 Monitoring. The system **MUST** show the supervisor active actors, current authority, pending approvals, completed actions, exceptions, failed registrations, scope consumption, and emergency-stop status with bounded delay appropriate to the risk.

HS-05 Automation bias. The interface **SHOULD** present model uncertainty, conflicting evidence, verification status, and known limitations in a form that helps the supervisor avoid automatic reliance on AI output [23].

HS-06 Supervisory record. Each approval, denial, constraint, override, intervention, and halt **MUST** be recorded as a distinct event attributed to the supervisor. Absence of a required approval **MUST** result in denial.

5.2 Authority and approval

AU-01 Authority grant. Every authority grant **MUST** state: grant identifier; grantor; grantee; role; permitted actions; resource scope; constraints; effective time; expiration or terminal condition; required evidence; applicable approval gates; and explicitly prohibited actions.

AU-02 Binding. An authority grant **MUST** be bound to the actor's authenticated identity and the operation identifier. Authority **MUST** fail closed when missing, expired, revoked, ambiguous, or inconsistent with a higher-priority policy.

AU-03 Least authority. The granted action and resource scope **MUST** be no broader than necessary for the approved operation. Discovery or read authority **MUST NOT** imply mutation authority [22].

AU-04 Distinct gates. The implementation **MUST** define separate approval gates for material lifecycle transitions, including mutation, commit or promotion, publication or deployment, destructive action, material scope expansion, and acceptance of residual risk. Approval at one gate **MUST NOT** imply approval at another.

AU-05 Scope drift. The operation **MUST** stop and request a new human decision when the requested action, resource, actor, risk, or expected effect falls outside the current grant.

5.3 Identity, delegation, and role separation

ID-01 Authenticated identity. Every human, AI agent, service, and delegated process **MUST** have an authenticated identifier bound to its audit statements. A display name or self-asserted agent label is insufficient.

ID-02 Delegation. Delegation **MUST** identify the delegating actor, receiving actor, assigned role, authority grant, operation, time bounds, and revocation status. Delegated authority **MUST NOT** exceed the delegator's authority.

ID-03 Role separation. Consequential governed operations **SHOULD** use distinct actors for execution, verification, and commitment or publication. A policy permitting role overlap **MUST** record the justification, risk acceptance, compensating controls, and approving supervisor.

ID-04 Verification representation. An executor's self-check, generated summary, test run, signature, or hash **MUST NOT** be represented as independent verification. Every verification result **MUST** identify the verifier, state the verifier's relationship to the executor, and record the acceptance criteria and evidence examined.

ID-05 Independent verification. For Level A conformance, an independent verifier **MUST** examine the resulting artifact and primary evidence against explicit acceptance criteria.

5.4 Event and provenance model

EV-01 Automatic capture. The system **MUST** automatically record material proposals, authority decisions, approvals, denials, actions, tool invocations, mutations, exceptions, escalations, verification results, promotions, publications, overrides, reversals, recovery actions, and halt events.

EV-02 Minimum record. Each material record **MUST** contain every field defined in Table 2. A field value **MAY** be marked `not_applicable` only when the field belongs to a level above the implementation's declared level or the field is semantically inapplicable to the event type. The schema profile **MUST** enumerate those conditions and their encoding. At Level G, `statement_id` and `receipt_ref` **MAY** be `not_applicable`. At Levels G and T, `verifier_id` **MAY** be `not_applicable` only when independent verification is not required for that event. Event-type conditions are limited to: `input_refs` or `output_refs` when the event has no material input or output; `decision` or `decision_basis` when the event records no decision; `prior_event_id` for the initial event in an operation; and `supersedes_event_id` when the event does not correct or supersede an earlier record. All other fields **MUST NOT** be marked `not_applicable`. A field that applies but cannot be determined **MUST** be marked explicitly as `unknown`; it **MUST NOT** be omitted or represented as `not_applicable`.

EV-03 Provenance relations. The implementation **SHOULD** represent people, software agents, activities, entities, delegation, association, attribution, use, generation, derivation, role, and plan using W3C PROV semantics or a documented lossless mapping.

EV-04 Truth status. Material claims **MUST** carry a controlled evidence status. At minimum, the vocabulary **MUST** distinguish verified observation, inference, hypothesis, and unknown. Historical records that are no longer current **SHOULD** be superseded through a new event rather than rewritten.

EV-05 Evidence linkage. A record describing an artifact or external state **MUST** contain a stable identifier and, where technically appropriate, a cryptographic digest or externally verifiable reference to the evidence examined.

EV-06 Duplicate submission handling. Approval and action submissions **MUST** carry a stable submission identifier. Repeated submission of the same identifier and content **MUST** produce at most one external effect and a deterministic replay result. Reuse of an identifier with different content **MUST** fail closed and **MUST** produce an attributable conflict event.

Table 2: Minimum event record schema.

Field	Meaning
event_id	Globally unique event identifier.
operation_id	Identifier joining all events in one governed operation.
event_type	Controlled event classification.
recorded_at	Trusted or qualified timestamp with stated clock source.
actor_id, actor_type	Authenticated actor and whether person, organization, software agent, or service.
role	Actor's role in this event.
human_supervisor_id	Accountable natural person for the operation.
authority_grant_id	Current grant evaluated for the action.
policy_id, policy_version	Registration and operational policy applied.
action, resource_scope	Requested or completed action and affected resources.
input_refs, output_refs	Stable identifiers and digests for material inputs and outputs.
decision, decision_basis	Approval result and referenced evidence or criteria.
truth_status	Verified, inferred, hypothesis, unknown, stale, or superseded.
prior_event_id	Logical predecessor in the operation history.
verifier_id	Independent verifier when required.
supersedes_event_id	Earlier record corrected or made stale by this event.
statement_id, receipt_ref	Signed statement identifier and transparency receipt.
confidentiality, retention	Access class and applicable retention rule.

5.5 Cryptographic transparency and custody

CT-01 Signed statement. Each consequential event **MUST** produce an authenticated signed statement whose protected metadata binds the issuer identity, subject, statement type, and content or content digest.

CT-02 Registration policy. A Transparency Service **MUST** authenticate the issuer, apply the registration policy current at registration time, record an accepted statement in a verifiable data structure, and issue a receipt proving inclusion.

CT-03 Reproducibility. The service **MUST** retain or make available enough information for an

Auditor to reproduce the registration checks, including the signed statement, applicable policy, trust anchors, and required collateral.

CT-04 Append-only history. Accepted statements **MUST** form an append-only sequence. A correction, revocation, or change in status **MUST** be represented by a new linked statement; accepted history **MUST NOT** be silently modified, deleted, or reordered.

CT-05 Non-equivocation. Level T and Level A implementations **MUST** provide evidence that relying parties observe a consistent statement history. The selected verifiable data structure and receipt profile **MUST** be declared.

CT-06 Independent custody. Level A implementations **MUST** anchor checkpoints or register statements with at least one independently controlled transparency service or custodian. A head digest stored and updated by the same authority as the event log does not satisfy this requirement.

CT-07 Evidence limits. Validation output **MUST** distinguish at least: statement signature validity; issuer authentication; policy acceptance; inclusion; consistency; checkpoint custody; statement accuracy; actor authority; and independent verification. Success in one category **MUST NOT** be reported as success in another.

5.6 Privacy, security, and disclosure

PS-01 Data minimization. Records **MUST** contain only information necessary for accountability, verification, risk management, and applicable obligations. Secrets, authentication tokens, and unnecessary personal data **MUST NOT** be placed in statement payloads.

PS-02 Separated views. Sensitive provenance receipts and evidence **MUST** be access controlled and logically separated from sanitized records intended for wider disclosure. A sanitized record **MUST** retain stable references sufficient to request or verify authorized evidence.

PS-03 Access accountability. Access to sensitive evidence, policy administration, trust-anchor changes, and key-management actions **MUST** itself be logged and subject to separation of duties.

PS-04 Key compromise. The implementation **MUST** define detection, notification, revocation, historical interpretation, recovery, and reissuance procedures for compromised actor and transparency-service keys.

5.7 Continuity and recovery

RC-01 Retention. Retention periods **MUST** be defined by event class, purpose, legal obligation, confidentiality, and recovery need. Expiration and lawful deletion actions **MUST** be recorded without falsifying prior inclusion evidence.

RC-02 Durable publication. At Level G, the implementation **MUST** define atomicity and failure behavior for event storage and **MUST** identify states in which an action succeeded but its required event record was not durably stored. At Levels T and A, the implementation **MUST** additionally define atomicity and failure behavior for checkpoint publication and receipt return and **MUST** identify states in which an action succeeded but its evidence registration did not.

RC-03 Backup and restore. At Level G, backup, restoration, and disaster-recovery procedures **MUST** preserve event order and applicable policies. At Levels T and A, those procedures **MUST** additionally preserve signed-statement order, receipts, trust anchors, and signing and transparency-key history. At Level A, those procedures **MUST** additionally preserve independent checkpoints, exercise

restoration, and retain evidence of each restoration test and its result.

RC-04 Post-recovery reconciliation. After recovery, an independent actor **MUST** compare restored state with independently held checkpoints or transparency evidence before normal operation resumes.

6 Operational state model

A governed operation **MUST** proceed through explicit states:

PROPOSED → **SCOPED** → **AUTHORIZED** → **EXECUTING** → **EVIDENCED** → **VERIFIED** → **PROMOTION-AUTHORIZED** → **PROMOTED** → **REVERIFIED** → **CLOSED**

At Levels G and T, **VERIFIED** means that a verification result has been recorded against explicit acceptance criteria with the verifier's identity and relationship to the executor declared; it does not by itself mean independent verification. At Level A, entry into **VERIFIED** additionally requires satisfaction of ID-05. The same distinction applies to **REVERIFIED**.

Any state **MUST** be able to transition to an exception state, including **PAUSED**, **DENIED**, **FAILED**, **HALTED**, or **RECOVERY REQUIRED**. A transition **MUST** identify its actor, authority, evidence, and applicable human decision. The implementation **MUST NOT** infer a later-state authorization from completion of an earlier state.

7 Conformance tests

The level shown is the minimum level for the test. Because conformance levels are cumulative, a Level G test also applies at Levels T and A, and a Level T test also applies at Level A. The requirement identifiers state the normative duties exercised by each test; this table is a minimum adversarial test set and does not replace the requirement-by-requirement evidence required by Section 3.

Table 3: Conformance tests.

Test	Level	Requirement IDs	Procedure	Required evidence
T-01	G	HS-01, HS-06, AU-04	Attempt a consequential action without a designated supervisor or approval.	Action denied; denial event and policy decision recorded.
T-02	G	AU-02, AU-05	Request an action outside an otherwise valid grant.	Scope drift detected; execution stopped; new decision requested.

Table 3: Conformance tests (continued)

Test	Level	Requirement IDs	Procedure	Required evidence
T-03	G	HS-03, HS-06	While an agent is executing, invoke the supervisor halt control and measure from acceptance of the authenticated request to the declared safe state.	Observed latency does not exceed the declared maximum; safe state and attributed intervention event recorded.
T-04	G	EV-06	Submit an approval or action twice with the same identifier and content, then reuse the identifier with different content.	At most one external effect; deterministic replay for identical content; differing content fails closed with a conflict event.
T-05	G	ID-04	Have the executor submit its own verification.	Record identified as self-check and not represented as independent verification.
T-06	T	CT-04, CT-05; CT-06 (A)	Alter, delete, reorder, or rechain historical records.	At T, receipt or consistency validation detects manipulation; at A, independent-checkpoint comparison also detects it.
T-07G	G	AU-02	Present an expired grant, revoked credential, or stale authorization policy.	Authorization fails closed with an attributable reason.
T-07T	T	CT-02	Present a forged statement issuer or stale registration policy.	Registration fails closed with an attributable reason.
T-08	G	PS-01, PS-02	Expose the sanitized audit view to an unauthorized reader.	Required accountability fields remain; sensitive evidence and secrets remain inaccessible.
T-09	A	CT-06, RC-03, RC-04	Restore from backup after newer independently anchored events exist.	Divergence detected; reconciliation required before normal operation.

Table 3: Conformance tests (continued)

Test	Level	Requirement IDs	Procedure	Required evidence
T-10	T	RC-02	Simulate action success followed by receipt-registration failure.	System exposes the inconsistent state and invokes containment or recovery policy.
T-11	T	PS-04	Compromise or rotate an issuer or transparency key.	Historical validity, revocation point, replacement key, and notifications remain auditable.
T-12G	G	EV-04	Correct a false historical claim.	New superseding event added; original record retained and linked.
T-12T	T	EV-04, CT-04	Correct a false historical claim registered with the transparency service.	New superseding statement added; original record and prior inclusion proof remain detectable.

8 Standards crosswalk

Table 4: Standards crosswalk.

HAIO-GATS domain	External reference	Relationship and limitation
Management system	ISO/IEC 42001:2023 [1]	Provides the organizational AI management-system umbrella, including leadership, responsibility, risk management, monitoring, and continual improvement. This profile adds event-level controls and evidence structures.
Governance	ISO/IEC 38507:2022 [2]	Addresses governance implications of organizational AI use and governing-body responsibility. This profile operationalizes supervisory control and evidence.

Table 4: Standards crosswalk (continued)

HAIO-GATS domain	External reference	Relationship and limitation
Impact assessment	ISO/IEC 42005:2025 [3]	Supports documented lifecycle impact assessment. This profile can preserve assessment decisions and resulting control changes.
AI risk management	ISO/IEC 23894:2023 [4]; NIST AI RMF 1.0 [5]	Supports risk-based governance, documented roles, monitoring, go/no-go decisions, and human-AI oversight. NIST AI RMF 1.0 is under revision as of the publication date.
Human oversight	Regulation (EU) 2024/1689, Article 14 [7]	Requires effective oversight for high-risk AI, including understanding limitations, monitoring, disregard, override, reversal, intervention, and safe stopping. Applicability depends on legal classification and context.
Automatic logging	Regulation (EU) 2024/1689, Article 12 [7]	Requires automatic event recording and traceability for high-risk AI. HAIO-GATS defines a broader operational record schema.
Provenance semantics	W3C PROV-DM [8] and PROV-O [9]	Provides interoperable Entity, Activity, Agent, association, delegation, attribution, role, and derivation relations. It does not itself guarantee truth, authority, or immutability.
Separation of duties	NIST SP 800-53 Rev. 5, AC-5 [6]	Supports distinct roles and access authorizations. HAIO-GATS applies the control to executor, verifier, and promotion roles.
Audit content and protection	NIST SP 800-53 Rev. 5, AU family [6]	Supports event selection, content, review, retention, time stamps, and audit-information protection. HAIO-GATS adds AI-operation semantics.
Cryptographic transparency	IETF RFC 9943 [10] and RFC 9942 [11]	Supplies signed statements, issuer authentication, registration policies, verifiable data structures, receipts, append-only history, and non-equivocation. Application to AI governance events is an HAIO-GATS profile beyond RFC 9943's motivating supply-chain use cases.

Table 4: Standards crosswalk (continued)

HAIO-GATS domain	External reference	Relationship and limitation
Merkle transparency	IETF RFC 9162 [12]	Supplies an established append-only log model and consistency proof design. It does not establish statement accuracy or operational authority.
Canonical JSON	IETF RFC 8785 [13]	May provide deterministic JSON representation before signing or digesting. Canonicalization does not provide custody or authenticity.
Trusted time	IETF RFC 3161 [14]	May support independent time-stamp tokens for selected events or checkpoints. It does not establish the semantic truth of an event.

9 Scientific claims and limitations

9.1 Testable claims

This specification supports empirical evaluation of the following propositions:

1. explicit authority objects reduce ambiguous delegation and unauthorized scope expansion;
2. effective supervisor controls reduce time to containment for anomalous agent behavior;
3. role separation improves detection of erroneous or unsupported completion claims;
4. signed provenance statements plus independently controlled transparency evidence improve detection of record rewriting and equivocation; and
5. structured event records reduce the cost of reconstructing who acted, under what authority, using which evidence, and with what result.

Implementations should report false-accept and false-reject rates for authorization decisions, supervisor intervention latency, missing-event rate, receipt-registration latency and failure rate, recovery-point divergence, verifier disagreement, and audit reconstruction time.

9.2 Limitations

HAIO-GATS does not make AI behavior safe merely by recording it. A dishonest authorized actor may sign a false statement; a compromised identity provider may authenticate an attacker; a supervisor may misunderstand an AI system or approve a harmful action; and colluding actors may defeat ordinary separation of duties. Cryptographic transparency increases detectability and accountability but cannot establish the accuracy, completeness, legality, or ethical acceptability of the registered content.

The profile also introduces operational cost, storage, privacy, key-management, and latency burdens. Risk-based tailoring is necessary, but tailoring decisions must themselves be documented and approved. Formal security analysis, usability studies of the supervisor interface, and independent evaluation across real agentic workflows remain future work.

10 Ethics, privacy, and responsible use

The audit system can become a surveillance system if it collects excessive personal data or gives broad access to detailed activity records. Implementers should perform an impact assessment, minimize recorded content, separate public and restricted evidence, protect whistleblowers and privileged material, define contest and correction procedures, and provide transparent retention and access rules. Research on distributed sociotechnical systems warns that responsibility can be misattributed to human operators who have limited control [24]. Analysis of human-oversight policies for government algorithms further shows that nominal oversight can fail to provide effective control [25]. Human supervision must be supported by competence, time, authority, and usable controls; assigning nominal responsibility without effective power does not satisfy this specification.

11 Conclusion

HAIO-GATS defines a standards-aligned scientific specification for accountable AI operations. Its central requirement is effective human supervisory control supported by bounded authority, explicit lifecycle gates, authenticated actor provenance, independent verification, and independently checkable evidence. The profile treats governance and cryptography as complementary layers and makes their respective claims and limits explicit.

Declarations

Author contribution. Paul Garrett Hugel conceived the specification and is the sole named author.

Funding. The author received no specific funding for this work.

Competing interests. The author declares no competing interests.

Data and code availability. No empirical dataset or executable reference implementation accompanies version 0.1.0. The specification and deposit metadata constitute the research outputs.

License. This work is licensed under the Creative Commons Attribution 4.0 International license.

Versioning. Material corrections should be released as a new version. Earlier deposited versions should remain accessible and should be linked through Zenodo versioning.

Recommended citation

Hugel, P. G. (2026). *Human-Supervised AI Operations Governance and Audit Trail Specification: A Standards-Aligned Profile for Accountable Agentic Workflows* (HAIO-GATS, Version 0.1.0). Zenodo. <https://doi.org/10.5281/zenodo.22800642>

Declaration of generative AI and AI-assisted technologies in the writing process

During the preparation of this work, the author used OpenAI Codex for structured drafting, editorial revision, document production, and standards and citation research, and Anthropic Claude for pre-publication review and citation validation. After using these tools, the author reviewed and edited the content as needed, retained all final editorial and publication decisions, and takes full responsibility for the content of the publication. Neither AI system is an author.

References

- [1] International Organization for Standardization. (2023). *ISO/IEC 42001:2023 Information technology – Artificial intelligence – Management system*. <https://www.iso.org/standard/42001>
- [2] International Organization for Standardization. (2022). *ISO/IEC 38507:2022 Information technology – Governance of IT – Governance implications of the use of artificial intelligence by organizations*. <https://www.iso.org/standard/56641.html>
- [3] International Organization for Standardization. (2025). *ISO/IEC 42005:2025 Information technology – Artificial intelligence – AI system impact assessment*. <https://www.iso.org/standard/42005>
- [4] International Organization for Standardization. (2023). *ISO/IEC 23894:2023 Information technology – Artificial intelligence – Guidance on risk management*. <https://www.iso.org/standard/77304.html>
- [5] National Institute of Standards and Technology. (2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*, NIST AI 100-1. <https://doi.org/10.6028/NIST.AI.100-1>
- [6] National Institute of Standards and Technology. (2020, updated 2025). *Security and Privacy Controls for Information Systems and Organizations*, SP 800-53 Rev. 5. <https://doi.org/10.6028/NIST.SP.800-53r5>
- [7] European Parliament and Council of the European Union. (2024). *Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence*. Official Journal of the European Union. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng>
- [8] Moreau, L., Missier, P., et al. (2013). *PROV-DM: The PROV Data Model*. W3C Recommendation. <https://www.w3.org/TR/prov-dm/>
- [9] Lebo, T., Sahoo, S., & McGuinness, D. (2013). *PROV-O: The PROV Ontology*. W3C Recommendation. <https://www.w3.org/TR/prov-o/>
- [10] Birkholz, H., Delignat-Lavaud, A., Fournet, C., Deshpande, Y., & Lasker, S. (2026). *An Architecture for Trustworthy and Transparent Digital Supply Chains*. RFC 9943. <https://www.rfc-editor.org/rfc/rfc9943>
- [11] Steele, O., Birkholz, H., Delignat-Lavaud, A., & Fournet, C. (2026). *CBOR Object Signing and Encryption (COSE) Receipts*. RFC 9942. <https://www.rfc-editor.org/rfc/rfc9942>
- [12] Laurie, B., Langley, A., Kasper, E., Messeri, E., & Stradling, R. (2021). *Certificate Transparency Version 2.0*. RFC 9162. <https://www.rfc-editor.org/rfc/rfc9162>
- [13] Rundgren, A., Jordan, B., & Erdtman, S. (2020). *JSON Canonicalization Scheme*. RFC 8785. <https://www.rfc-editor.org/rfc/rfc8785>
- [14] Adams, C., Cain, P., Pinkas, D., & Zuccherato, R. (2001). *Internet X.509 Public Key Infrastructure Time-Stamp Protocol*. RFC 3161. <https://www.rfc-editor.org/rfc/rfc3161>
- [15] Bradner, S. (1997). *Key words for use in RFCs to Indicate Requirement Levels*. BCP 14, RFC 2119. <https://www.rfc-editor.org/rfc/rfc2119>

[16] Leiba, B. (2017). *Ambiguity of Uppercase vs Lowercase in RFC 2119 Key Words*. BCP 14, RFC 8174. <https://www.rfc-editor.org/rfc/rfc8174>

[17] Schneier, B., & Kelsey, J. (1999). Secure audit logs to support computer forensics. *ACM Transactions on Information and System Security*, 2(2), 159–176. <https://doi.org/10.1145/317087.317089>

[18] Ma, D., & Tsudik, G. (2009). A new approach to secure logging. *ACM Transactions on Storage*, 5(1), 1–21. <https://doi.org/10.1145/1502777.1502779>

[19] Haber, S., & Stornetta, W. S. (1991). How to time-stamp a digital document. *Journal of Cryptology*, 3(2), 99–111. <https://doi.org/10.1007/BF00196791>

[20] Chan, A., Ezell, C., Kaufmann, M., Wei, K., et al. (2024). Visibility into AI agents. In *Proceedings of the 2024 ACM Conference on Fairness, Accountability, and Transparency* (pp. 958–973). <https://doi.org/10.1145/3630106.3658948>

[21] Parasuraman, R., Sheridan, T. B., & Wickens, C. D. (2000). A model for types and levels of human interaction with automation. *IEEE Transactions on Systems, Man, and Cybernetics – Part A: Systems and Humans*, 30(3), 286–297. <https://doi.org/10.1109/3468.844354>

[22] Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. *Proceedings of the IEEE*, 63(9), 1278–1308. <https://doi.org/10.1109/PROC.1975.9939>

[23] Parasuraman, R., & Manzey, D. H. (2010). Complacency and bias in human use of automation: An attentional integration. *Human Factors*, 52(3), 381–410. <https://doi.org/10.1177/0018720810376055>

[24] Elish, M. C. (2019). Moral crumple zones: Cautionary tales in human-robot interaction. *Engaging Science, Technology, and Society*, 5, 40–60. <https://doi.org/10.17351/ests2019.260>

[25] Green, B. (2022). The flaws of policies requiring human oversight of government algorithms. *Computer Law & Security Review*, 45, 105681. <https://doi.org/10.1016/j.clsr.2022.105681>

[26] Sharif, R. (2026). *Agent Audit Trail: A Standard Logging Format for Autonomous AI Systems* (Internet-Draft draft-sharif-agent-audit-trail-04). IETF. Work in progress. <https://datatracker.ietf.org/doc/draft-sharif-agent-audit-trail/04/>

A Zenodo deposit metadata

Table 5: Zenodo deposit metadata.

Title	Human-Supervised AI Operations Governance and Audit Trail Specification: A Standards-Aligned Profile for Accountable Agentic Workflows
Creator	Paul Garrett Hugel
ORCID	0000-0001-8082-7208
Publication date	2026-09-16
Resource type	Publication / Technical note
Version	0.1.0
Language	English
Access	Open access
License	Creative Commons Attribution 4.0 International (CC BY 4.0)
DOI	10.5281/zenodo.22800642

B Change record

Table 6: Change record.

Version	Date	Change
0.1.0	2026-09-16	Initial public draft defining human supervisory control, bounded authority, event provenance, cryptographic transparency, independent custody, and conformance tests.